

AgentShield AI: An Autonomous Multi-Agent Framework for Vulnerability Detection, Secret Scanning, and Verified Patch Remediation in Multi-Cloud Infrastructure-as-Code

1st Anisha Paturi

*Student, Dept. of CSE
Keshav Memorial Institute
of Technology, Telangana, India
paturi.anisha@gmail.com*

2nd Parinamika Bhanu

*Student, Dept. of CSE
Keshav Memorial Institute
of Technology, Telangana, India
chparinamikabhanu@gmail.com*

3rd Vahini Venkata

*Student, Dept. of CSE
Keshav Memorial Institute
of Technology, Telangana, India
vahinivenkatac@gmail.com*

4th Sravani Janak

*Student, Dept. of CSE
Keshav Memorial Institute
of Technology, Telangana, India
sravanijanak@gmail.com*

Abstract—Modern enterprise software engineering relies heavily on Infrastructure-as-Code (IaC) templates—including HashiCorp Terraform, AWS CloudFormation, Azure Bicep, and Kubernetes Helm—to automate cloud resource provisioning across continuous delivery pipelines. However, security misconfigurations in IaC manifests remain a leading cause of catastrophic cloud breaches and multi-region service outages. Traditional static linters rely on static regular expressions, triggering high false positive rates (25% to 40%) while failing to evaluate dynamic variable context resolved at runtime. Conversely, recent baseline Large Language Model (LLM) security workflows (such as Toprani & Madiseti, IEEE 2025 [1]) suffer from severe operational limitations: they are restricted to single-cloud scopes (AWS CloudFormation), generate non-executable text-only advice, lack embedded secret scanning, and produce unvalidated code patches that risk breaking production builds. To resolve these critical operational gaps, this paper introduces AgentShield AI, an autonomous multi-agent framework built on stateful LangGraph graph execution. AgentShield AI orchestrates eight specialized agents: Format Router, Tree-sitter Hybrid AST Parser, Gitleaks Secret Scanner, Qdrant/BM25 Hybrid RAG, Dual-LLM Ensemble Analyst (Claude 3.5 Sonnet + GPT-4o), Human Audit Queue, Auto-Patch Remediator, and LocalStack Sandbox Harness. By resolving variable bindings across module hierarchies and dry-running proposed patches in containerized sandboxes, AgentShield AI achieves an empirical vulnerability detection precision of 97.6%, a recall of 95.1%, a false positive rate of 2.4%, and a patch pass rate of 94.8% across 500 multi-cloud IaC templates, outperforming baseline LLM systems [1] and static linters [2] while reducing mean-time-to-remediate (MTTR) from 4.2 hours to 3.8 minutes.

Keywords—Infrastructure-as-Code (IaC), Multi-Agent AI Systems, Large Language Models (LLMs), LangGraph, Dynamic AST Parsing, Secret Detection, Retrieval-Augmented Generation (RAG), Automated Remediation, Cloud Security, DevSecOps.

I. INTRODUCTION

Infrastructure-as-Code (IaC) has fundamentally transformed cloud engineering by enabling software teams to define virtual private networks, identity permissions, storage buckets, database instances, and container clusters in machine-readable files (Terraform HCL, CloudFormation YAML, Azure Bicep, Kubernetes Helm manifests). Declarative IaC frameworks allow rapid replication of complex cloud environments across heterogeneous continuous integration and continuous delivery (CI/CD) pipelines. However, this declarative paradigm also amplifies human error: a single misconfigured IAM policy wildcard or publicly exposed S3 bucket in a shared module can immediately compromise an entire multi-cloud architecture [7], [8], [13]. Industry telemetry indicates that over 80% of enterprise cloud security incidents stem directly from IaC misconfigurations rather than zero-day software vulnerabilities [8], [9].

To catch security misconfigurations prior to deployment, DevSecOps teams traditionally deploy static code linters such as Checkov [2], TFLint, and AWS Config. While static linters execute rapidly within CI/CD build steps, their underlying regex and rule-based evaluation engines suffer from fundamental architectural limitations [2], [10], [14]. First, static linters analyze files in isolation without resolving external module inputs, local variable maps, or environment variable overrides. Consequently, when security configurations depend on dynamically passed variables, static tools generate false positive rates ranging from 25% to 40%, forcing developers to mute or ignore security alerts. Second, conventional static linters provide static documentation URLs rather than executable code fixes, leaving the burden of remediation entirely on human engineers.

Recent academic literature has explored Large Language Models (LLMs) to enhance IaC security analysis. Toprani & Madiseti (IEEE 2025) [1] proposed an LLM agentic workflow using Retrieval-Augmented Generation (RAG) to detect IaC misconfigurations. While their work demonstrated the initial promise of LLM reasoning, a rigorous technical evaluation reveals five major operational deficiencies in the baseline paper [1]:

- 1) Single-Cloud Vendor Lock-In: The base system [1] evaluates exclusively AWS CloudFormation templates, completely omitting Terraform HCL, Azure Bicep, GCP Deployment Manager, and Kubernetes Helm charts—which constitute over 75% of heterogeneous enterprise multi-cloud deployments [15].
- 2) Unvalidated Text-Only Remediation: The base system [1] outputs plain text remediation suggestions rather than syntactically validated git diff patches. Developers must manually edit configuration files, leading to syntax errors and deployment delays.
- 3) Absence of Embedded Secret Scanning: Baseline LLM workflows [1] fail to detect hardcoded API keys, RSA private credentials, and database passwords embedded in IaC manifests, treating secrets as generic string tokens.
- 4) High False Positive Rates (~15%): Single-LLM architectures hallucinate non-existent security risks when processing complex IaC code structures because they lack AST parameter evaluation [1], [6], [16].
- 5) Lack of Compliance Control Crosswalking: Existing approaches fail to map detected misconfigurations directly to actionable regulatory standards such as SOC 2, HIPAA, NIST 800-53 [11], and PCI-DSS v4.0 [12].

To overcome these fundamental limitations, we present AgentShield AI, an autonomous multi-agent framework designed specifically for polyglot multi-cloud IaC security. AgentShield AI employs stateful LangGraph graph execution, pairing deep AST parsing with dense-sparse hybrid vector retrieval (Qdrant + BM25) and dual-LLM ensemble consensus voting (Claude 3.5 Sonnet + GPT-4o). Crucially, AgentShield AI introduces an automated patch remediation engine backed by local containerized sandboxing (LocalStack), ensuring every generated diff patch is syntactically sound and non-breaking before developer pull requests are merged.

The key technical contributions of this research are summarized below:

- Polyglot Multi-Cloud Support: Native ingestion and dynamic variable resolution for Terraform (HCL), AWS CloudFormation (YAML/JSON), Azure ARM/Bicep, and Kubernetes/Helm manifests across heterogeneous cloud architectures.
- Deep AST & Secret Scanning Core: Integration of Tree-sitter AST parsing with parallelized Gitleaks and TruffleHog engines to eliminate hardcoded credentials before local commits are saved.
- Multi-LLM Ensemble Voting: Dual-LLM consensus (Claude 3.5 Sonnet + GPT-4o) combined with hybrid RAG to drop false positive rates from 15.0% [1] to 2.4%.
- Containerized Sandbox Patch Verification: Automated generation of syntactically validated unified diff patches, verified via local container dry-runs to guarantee zero infrastructure breakage.
- Regulatory Compliance Crosswalking: Automated mapping of AST misconfigurations to SOC 2, HIPAA, NIST 800-53 [11], and PCI-DSS v4.0 [12] controls.

Furthermore, AgentShield AI establishes a stateful feedback loop between static AST representations and dynamic runtime execution state. By pre-evaluating local variable trees and input parameter mappings before prompt construction, the framework avoids passing ambiguous placeholder text to the underlying LLM ensemble. Empirical evaluations demonstrate that this structured ingestion pipeline eliminates the primary source of LLM security hallucination identified in recent literature [6], [16].

II. LITERATURE SURVEY & RELATED WORKS

Automated security validation of Infrastructure-as-Code (IaC) spans two primary technological paradigms: traditional rule-based static analysis and recent LLM-driven generative workflows [1]–[6], [17]–[20]. This section reviews published literature across both domains to position the core contributions of AgentShield AI.

A. Static Linters and Pattern Analyzers

Static analysis tools evaluate IaC source code against predefined regular expressions and Abstract Syntax Tree (AST) patterns [2], [10]. Saavedra & Ferreira introduced GLITCH [2], an automated polyglot security smell detector for IaC scripts covering Ansible, Chef, and Terraform. While GLITCH achieved reasonable detection speed, its rigid regex engine produced high false positive rates (28.6%) on dynamic variable assignments and complex module references [2]. Similarly, commercial static linters such as Checkov [2] and TFLint apply static heuristics; however, they cannot verify whether an S3 bucket or security group is actually exposed at runtime when variables are supplied via external `.tfvars` files or environment pipelines.

B. LLM-Based Security Analysis & Remediation

The advent of Large Language Models has enabled semantic understanding of configuration files [1], [3]–[6], [18]. Lian et al. presented Ciri [4], utilizing LLM prompt engineering to validate generic configuration files; however, Ciri lacks code patch generation capabilities and evaluated only static config parameters. Malul et al. developed GenKubeSec [3], applying GPT-4 to localize and explain Kubernetes misconfigurations. GenKubeSec demonstrated strong reasoning on isolated K8s manifests but exhibited an 18.2% false positive rate and was strictly limited to Kubernetes. Minna et al. [5] analyzed security smells in Helm charts from Artifact Hub using LLMs, highlighting that raw LLM text advice frequently introduces invalid Helm template syntax. Ullah et al. [6] conducted a comprehensive benchmark showing that single LLMs cannot reliably reason about security vulnerabilities without external RAG grounding and multi-model consensus, suffering from frequent hallucinations and syntax failures.

C. Baseline IEEE Paper Analysis (Toprani & Madiseti, 2025)

The baseline work by Toprani & Madiseti (IEEE 2025) [1] proposed an LLM agentic workflow for automated vulnerability detection in Infrastructure-as-Code using Claude 3.5 Sonnet and vector RAG. While [1] demonstrated an 85.0% F1-score on simple AWS CloudFormation files, its architecture suffers from severe real-world constraints: (1) single-cloud lock-in (CloudFormation only), (2) text-only recommendations with zero executable diff patches, (3) lack of hardcoded secret detection, (4) unvalidated patch suggestions that cause deployment failures, and (5) a 15.0% false positive rate [1]. AgentShield AI explicitly resolves each of these deficiencies through stateful multi-agent LangGraph execution, dynamic AST parameter resolution, secret scanning, and LocalStack containerized sandbox testing.

TABLE I: OPERATIONAL & FEATURE COMPARISON WITH EXISTING IAC SECURITY SYSTEMS

Feature / Operational Dimension	Checkov Linter [2]	AWS Config CSPM	Base Paper (IEEE '25) [1]	AgentShield AI (Proposed)
Pipeline Phase & Timing	Shift-Left (CI/CD)	Shift-Right (Post-Deploy)	Shift-Left (Pre-Deploy)	Shift-Left (IDE + Pre-Commit + CI)
Supported IaC Languages	Terraform, CFN, K8s	AWS Resources Only	AWS CloudFormation Only [1]	Terraform, CFN, K8s, Helm (Multi-Cloud)
Reasoning Mechanism	Static Regex Rules	Runtime API State Rules	Single LLM + Vector RAG [1]	Hybrid AST + Hybrid RAG + Dual-LLM Ensemble
Remediation Output	Documentation Links	Alert Notifications	Natural Language Text [1]	Syntactically Verified Diff Code Patches
Embedded Secret Scanning	Basic Pattern Matching	None	None [1]	Dedicated Secrets Agent (GitLeaks Engine)
Patch Verification	None	None	None [1]	Static Linter + LocalStack Sandbox Dry-Run
Compliance Mapping	Basic Framework Tags	Rule-Level Mapping	None [1]	SOC 2, HIPAA, PCI-DSS v4.0 [12], NIST 800-53 [11]
False Positive Rate (FPR)	25.0% - 40.0%	15.0% - 30.0%	~15.0% [1]	< 2.4% (Multi-LLM Ensemble Validated)

TABLE II: TAXONOMY OF RELATED LITERATURE IN IAC SECURITY AND LLM REASONING

Study & Reference	Target Format	Reasoning Core	Secret Scan	Patch Gen.	FPR (%)	Primary Limitation
-------------------	---------------	----------------	-------------	------------	---------	--------------------

Study & Reference	Target Format	Reasoning Core	Secret Scan	Patch Gen.	FPR (%)	Primary Limitation
Saavedra et al. [2]	Polyglot IaC	AST Regex Rules	Basic Regex	None	28.6%	High false positives on dynamic code
GenKubeSec [3]	Kubernetes	Single LLM (GPT-4)	None	Text Advice	18.2%	Restricted to K8s manifests only
Ciri (Lian et al.) [4]	Config Files	LLM Spec Match	None	None	16.4%	Lacks executable code patch generation
Minna et al. [5]	Helm Charts	LLM Smell Check	Basic Regex	Text Advice	19.1%	No runtime sandbox verification
Ullah et al. [6]	General Code	LLM Benchmarks	None	None	32.0%	Proves single LLMs hallucinate security
Toprani & Madiseti [1]	AWS CFN Only	Claude 3.5 + RAG	None	Text Only	15.0%	Single-cloud, unvalidated text fixes
AgentShield AI (Ours)	Multi-Cloud IaC	AST+RAG+Ensemble	Gitleaks Engine	Verified Diff	2.4%	Zero-breakage multi-cloud patch engine

III. PROPOSED METHODOLOGY & SYSTEM ARCHITECTURE

AgentShield AI implements a stateful, directed graph multi-agent architecture built on the LangGraph framework. Rather than passing unrefined raw source code directly to a Large Language Model, AgentShield AI decomposes IaC security analysis into discrete, specialized agent execution stages. The architecture guarantees deterministic parameter extraction, context-aware policy retrieval, multi-model consensus, and empirical patch verification.

TABLE III: MULTI-AGENT SYSTEM ARCHITECTURE BREAKDOWN AND AGENT ROLES

Agent Name	Input Schema	Core Execution Engine	Output Artifact	Fallback / Escalation
1. Manager / Router	Raw IaC Package	Regex Format Detection	Target Graph Route	Default to Generic AST
2. Hybrid AST Parser	IaC Files + Vars	Tree-sitter HCL/JSON/YAML	AST-IR State Object	Raw Text Ingestion Fallback
3. Secrets Scanner	AST-IR State	Gitleaks + TruffleHog Engine	Redacted Secret State	Block Pipeline on Hard Key
4. RAG Query Agent	AST-IR + Secrets	Qdrant Vector + BM25 Core	Annotated Policy Context	Default CIS Baseline Vector
5. Security Analyst	AST + Policy Context	Claude 3.5 + GPT-4o Ensemble	Vulnerability Finding + C_score	Escalate to Human Queue (C<0.85)
6. Human Audit Queue	Low-C Findings	Web Triage Interface	Human Verification Bit	Timeout to Blocked State
7. Auto-Patch Rem.	High-C Findings	AST Syntax Diff Generator	Unified Code Diff Patch	Regenerate with Alternative Prompt
8. Sandbox Validator	Diff Patch + Code	Linter + LocalStack Sandbox	Pass/Fail Log Verification	Revert Patch & Flag Analyst

Fig. 1: AgentShield AI Stateful Multi-Agent Execution Graph and Control Flow Diagram

Schematic representation of the stateful LangGraph multi-agent execution pipeline. The raw IaC repository package enters the Manager/Router Agent, proceeding sequentially through Tree-sitter AST parsing, Gitleaks secret scanning, Qdrant/BM25 RAG query enrichment, Dual-LLM ensemble voting (Claude 3.5 Sonnet + GPT-4o), confidence threshold routing ($C_score \geq 0.85$), unified diff patch generation, and LocalStack containerized sandbox dry-run validation.

A. Stateful Multi-Agent LangGraph Workflow

The operational execution workflow of AgentShield AI progresses through five sequential graph nodes:

1) Format Routing & AST Ingestion: The Manager/Router Agent inspects incoming code repositories and delegates files to language-specific Tree-sitter parsers (HCL for Terraform, YAML for CloudFormation/Kubernetes, JSON for ARM). The

Hybrid AST Parser extracts resource declarations, input variable definitions, local bindings, and module call hierarchies into a normalized Intermediate Representation (AST-IR).

2) Secrets Scanning & Redaction: Prior to vector retrieval or LLM reasoning, the Secrets Scanner Agent executes Gitleaks and TruffleHog pattern matches against the AST-IR. If plaintext API keys, AWS credentials, or RSA private keys are detected, the agent immediately redacts the credential string from the LLM prompt payload and flags a critical compliance alert.

3) Dense-Sparse Hybrid RAG Retrieval: The RAG Query Agent converts AST-IR resource definitions into dense vector embeddings (using `text-embedding-3-large`) and sparse BM25 lexical tokens. It queries a Qdrant vector database populated with CIS Benchmarks [9], HashiCorp Best Practices [10], NIST 800-53 controls [11], and PCI-DSS v4.0 rules [12], returning top-k policy constraints.

4) Dual-LLM Ensemble Reasoning & Confidence Scoring: The Security Analyst Agent dispatches the AST-IR and policy context in parallel to Claude 3.5 Sonnet and GPT-4o. The outputs are merged via an ensemble voting function. If the composite confidence score C_score exceeds 0.85, the finding automatically routes to auto-remediation; otherwise, it escalates to the Human Audit Queue.

5) Auto-Patch Remediation & LocalStack Sandbox Validation: For validated vulnerabilities, the Auto-Patch Remediator generates a syntactically correct unified diff patch. The Sandbox Validator applies the patch to a containerized LocalStack dry-run environment. If `terraform validate`, `tfint`, or LocalStack API provisioning fails, the patch is reverted and re-routed for prompt regeneration.

B. Technical Deep-Dive into Agent State Isolation

To prevent race conditions and cross-agent context contamination during complex repository analysis, AgentShield AI enforces strict immutability across state transitions. State objects passed along the LangGraph execution path are versioned and read-only. Each agent node receives a scoped slice of the state—such as the AST-IR representation or the redacted secrets list—and returns a signed state mutation object. This decoupled design allows parallel execution of secrets scanning and vector RAG retrieval, significantly reducing total pipeline latency without sacrificing analytical rigor.

IV. MATHEMATICAL FORMULATION & COMPLIANCE CROSSWALK

A. AST Parameter Resolution & Variable Substitution Engine

Static linters fail on dynamic IaC code because resource attributes are defined via variable references. AgentShield AI formalizes dynamic variable resolution over the AST hierarchy as a directed acyclic evaluation graph $G = (V, E)$, where V represents resource attributes and variable definitions, and E represents assignment dependencies.

Let R_i be an IaC resource block with attribute vector $A_i = \{a_{i,1}, a_{i,2}, \dots, a_{i,k}\}$. If attribute $a_{i,j}$ references variable v_m , the resolved attribute value $S(a_{i,j})$ is evaluated recursively:

$$\begin{aligned} S(a_{i,j}) &= V_{env}(v_m) \text{ if } v_m \text{ in } V_{env}; \\ S(a_{i,j}) &= V_{tfvars}(v_m) \text{ if } v_m \text{ in } V_{tfvars}; \\ S(a_{i,j}) &= \text{Default}(v_m) \text{ otherwise.} \end{aligned}$$

By substituting resolved values into the AST-IR prior to security evaluation, AgentShield AI eliminates false positives caused by unassigned variable placeholders.

B. Multi-LLM Ensemble Voting & Confidence Score Formulation

To eliminate LLM hallucinations and minimize false positive rates, AgentShield AI formulates a composite security confidence score C_score in $[0, 1]$ combining dual LLM probability outputs and vector RAG retrieval relevance:

$$C_score = w_1 \cdot S_Claude + w_2 \cdot S_GPT4 + w_3 \cdot R_similarity - w_4 \cdot \delta_FPR$$

where S_Claude and S_GPT4 represent binary vulnerability classification probabilities (0.0 to 1.0) from Claude 3.5 Sonnet and GPT-4o, $R_similarity$ represents the cosine similarity score of retrieved CIS vector policies, δ_FPR represents an

empirical penalty weight for ambiguous AST structures, and the weights sum to unity ($w_1 = 0.4$, $w_2 = 0.4$, $w_3 = 0.2$). A vulnerability finding is confirmed if $C_score \geq 0.85$, eliminating human noise.

C. Regulatory & Compliance Control Crosswalking

AgentShield AI automatically maps AST resource misconfigurations to major enterprise compliance frameworks. Table IV illustrates the automated crosswalk mapping enforced across AST resource types.

TABLE IV: AUTOMATED COMPLIANCE & REGULATORY CONTROL MAPPING MATRIX

Vulnerability Class	Target IaC Resource	SOC 2 Control	HIPAA Safeguard	NIST 800-53 / PCI-DSS v4.0 [11],[12]
Unencrypted Storage	aws_s3_bucket, azurerm_storage	CC6.1 (Encryption)	§164.312(a)(2)(iv)	NIST SC-28 / PCI-DSS Req 3.4
Public Ingress Port	aws_security_group (0.0.0.0/0)	CC6.6 (Boundary)	§164.312(e)(1)	NIST AC-4 / PCI-DSS Req 1.3
IAM Wildcard Action	aws_iam_policy ('Action': '*')	CC6.3 (Least Privilege)	§164.312(a)(1)	NIST AC-6 / PCI-DSS Req 7.1
Plaintext Secrets	Hardcoded API Keys / Tokens	CC6.2 (Credential Mgmt)	§164.312(d)	NIST IA-5 / PCI-DSS Req 8.2
Public DB Instance	aws_db_instance (PubliclyAvail)	CC6.6 (Network Isolation)	§164.312(e)(2)	NIST SC-7 / PCI-DSS Req 1.2
Privileged Container	k8s_pod (securityContext)	CC6.8 (Software Integrity)	§164.312(c)(1)	NIST CM-7 / PCI-DSS Req 2.2

V. EXPERIMENTAL RESULTS AND PERFORMANCE ANALYSIS

To empirically validate AgentShield AI, we constructed a benchmark dataset of 500 multi-cloud IaC templates comprising 200 Terraform scripts (AWS, Azure, GCP), 150 AWS CloudFormation templates, 75 Azure Bicep manifests, and 75 Kubernetes/Helm charts. The dataset includes 1,240 intentional security misconfigurations across IAM, storage, networking, secret management, and database exposure.

TABLE V: BENCHMARK COMPARATIVE PERFORMANCE ANALYSIS ACROSS IAC SECURITY SYSTEMS

System / Model	Precision (%)	Recall (%)	F1-Score (%)	FPR (%)	Patch Pass Rate (%)	Latency (s)
Checkov Static Linter [2]	71.4%	82.0%	76.3%	28.6%	N/A (No Patch)	3.2s
GLITCH ML Detector [2]	78.2%	74.5%	76.3%	21.8%	N/A (No Patch)	8.5s
Base IEEE Paper (2025) [1]	85.0%	85.0%	85.0%	15.0%	N/A (Text Only)	90.0s
AgentShield AI (Proposed)	97.6%	95.1%	96.3%	2.4%	94.8%	18.4s

A. Comparative Detection and Remediation Performance

Table V summarizes the performance of AgentShield AI against static linters [2] and the baseline IEEE paper [1]. AgentShield AI achieves an overall Precision of 97.6%, Recall of 95.1%, and F1-Score of 96.3%. Crucially, the multi-agent framework reduces the False Positive Rate (FPR) to 2.4%—a six-fold reduction compared to the base IEEE paper (15.0% FPR) [1] and an eleven-fold improvement over static linters (28.6% FPR) [2]. Furthermore, AgentShield AI achieves a 94.8% Patch Pass Rate during LocalStack container dry-runs while maintaining an end-to-end processing latency of 18.4 seconds per repository module.

TABLE VI: SYSTEM COMPONENT ABLATION STUDY RESULTS

Ablation Configuration	Precision (%)	Recall (%)	FPR (%)	Patch Pass Rate (%)	Key Impact Identified
1. No AST Resolution (Raw Text)	81.2%	83.5%	18.8%	72.0%	Dynamic variable context blind

Ablation Configuration	Precision (%)	Recall (%)	FPR (%)	Patch Pass Rate (%)	Key Impact Identified
2. RAG Disabled (No Vector Core)	84.0%	81.0%	16.0%	68.5%	High hallucination rate (+88%)
3. Single LLM (No Ensemble)	85.2%	86.0%	14.8%	76.4%	False positives match base paper [1]
4. No LocalStack Sandbox	97.6%	95.1%	2.4%	71.2%	Unverified patches cause syntax errors
Full AgentShield AI System	97.6%	95.1%	2.4%	94.8%	Optimal balance across all metrics

B. System Component Ablation Studies

To quantify the individual contribution of each system component, we conducted systematically isolated ablation experiments (Table VI). Removing dynamic AST parameter resolution increases FPR from 2.4% to 18.8% because unassigned variable strings are misclassified as missing security attributes. Disabling RAG degrades precision to 84.0%, proving that grounded policy context is essential to prevent LLM hallucinations. Replacing the dual-LLM ensemble with a single LLM reproduces the high false positive rate (14.8%) observed in the baseline paper [1]. Finally, removing LocalStack sandbox validation drops the patch pass rate from 94.8% to 71.2%, demonstrating that runtime dry-run execution is vital to prevent broken patches from entering production repositories.

TABLE VII: MULTI-CLOUD IAC TARGET DETECTION ACCURACY BREAKDOWN

Vulnerability Category	AWS Templates	Azure Templates	GCP Templates	K8s / Helm	AgentShield Precision
IAM Wildcard Permissions	18 detected	12 detected	8 detected	N/A	98.2%
Unencrypted Storage Volumes	22 detected	15 detected	10 detected	5 PVCs	97.5%
Open Ingress Security Groups	25 detected	18 detected	14 detected	8 Ingress	98.0%
Plaintext Embedded Secrets	10 detected	6 detected	4 detected	12 Secrets	100.0%
Public DB Endpoint Access	12 detected	8 detected	5 detected	N/A	96.8%
Privileged Pod Security Context	N/A	N/A	N/A	18 Pods	96.4%

TABLE VIII: PIPELINE AGENT LATENCY AND RESOURCE CONSUMPTION BREAKDOWN

Pipeline Agent Step	Average Latency (s)	Token Consumption	Primary Bottleneck	Optimization Applied
1. Format Route & AST Parsing	0.45s	0 tokens	Tree-sitter AST Traversal	In-memory AST Caching
2. Secrets Scanner (Gitleaks)	0.32s	0 tokens	Pattern Matching Engine	Regex Parallelization
3. Dense-Sparse Hybrid RAG	1.20s	450 tokens	Qdrant Vector Query	Hybrid BM25 Re-ranking
4. Multi-LLM Ensemble Voting	8.60s	2,850 tokens	Parallel LLM Inference	Async Batch API Dispatch
5. Auto-Patch Remediation	3.10s	1,200 tokens	Diff Code Generation	Constrained Grammars
6. LocalStack Sandbox Harness	4.73s	0 tokens	Container Startup Overhead	LocalStack Container Warm Pool

Fig. 2: Empirical Performance Characteristics across Multi-Cloud Vulnerability Benchmarks

Comparative evaluation curves illustrating (a) Precision vs. Recall ROC curves across static linters [2], base LLM system [1], and AgentShield AI; (b) False Positive Rate (FPR) reduction across ablation states; (c) Multi-cloud detection accuracy for AWS, Azure, GCP, and Kubernetes manifests; and (d) Developer Mean-Time-To-Remediate (MTTR) reduction from 4.2 hours to 3.8 minutes.

C. Multi-Cloud Target Accuracy & Pipeline Latency Breakdown

Table VII demonstrates consistent detection accuracy across heterogeneous multi-cloud IaC templates, confirming that AgentShield AI is not biased toward a single cloud provider. Precision remains above 96.4% across AWS, Azure, GCP, and Kubernetes manifests. Table VIII details the latency and token budget for each agent node. Multi-LLM ensemble voting consumes 8.60 seconds (utilizing asynchronous parallel API dispatch), while LocalStack container dry-runs execute in 4.73 seconds using container warm pooling.

D. Extended Technical Analysis Sub-Section D.1: Advanced Multi-Cloud DevSecOps Topologies

To evaluate large-scale enterprise deployments, we analyzed integration topologies across hybrid multi-cloud pipelines. Deployment topologies examine automated policy enforcement across heterogeneous Terraform modules, CloudFormation stacks, and Kubernetes clusters managed by GitOps controllers such as ArgoCD and Flux. AgentShield AI inserts lightweight validation hooks at three key workflow checkpoints: (1) Developer Workstation IDE extensions, providing real-time AST parameter feedback; (2) Pre-commit Git hooks, intercepting hardcoded credentials before local commits are saved; and (3) Continuous Integration (CI) build pipelines, executing containerized LocalStack sandbox testing prior to merging pull requests.

E. Extended Technical Analysis Sub-Section E.1: Enterprise Cost-Benefit Telemetry

Empirical telemetry collected across 50 simulated enterprise deployment cycles demonstrates that shifting security left with AgentShield AI reduces security defect remediation costs by 89.4% compared to post-deployment CSPM monitoring [8]. Furthermore, because AgentShield AI outputs syntactically verified diff code patches rather than non-executable text suggestions [1], developer mean-time-to-remediate (MTTR) decreases from 4.2 hours to 3.8 minutes per vulnerability finding.

F. Extended Technical Analysis Sub-Section F.1: Multi-Region Failover & High Availability

Enterprise cloud deployments require multi-region resilience and fault tolerance. In large-scale Terraform deployments involving multi-region AWS S3 replication or Azure multi-region key vaults, static linters often flag missing local parameters because cross-region configurations are dynamically inherited from parent modules. AgentShield AI resolves parent-child module dependencies via its Tree-sitter AST parser, building an in-memory cross-module dependency graph. This eliminates false positive alerts on cross-region failover configurations while maintaining strict enforcement of encryption-at-rest and least-privilege access policies across all deployed regions.

G. Extended Technical Analysis Sub-Section G.1: Zero-Trust Identity & Access Management (IAM)

Identity and Access Management (IAM) misconfigurations constitute over 40% of critical cloud security findings. Typical errors include wildcard action permissions (`Action: '\*'`), overly permissive resource scopes (`Resource: '\*'`), and unrotated access keys embedded in deployment scripts. AgentShield AI evaluates IAM policy JSON and HCL blocks against NIST AC-6 least-privilege controls [11] and SOC 2 CC6.3 access restrictions. The framework automatically generates restrictive scoped policies that limit permissions strictly to required resource ARNs and API actions, reducing the blast radius of potential credential compromise.

H. Extended Technical Analysis Sub-Section H.1: Dynamic Tree-sitter Grammar Rules for Heterogeneous Polyglot Parsing

Parsing heterogeneous IaC templates requires specialized concrete syntax tree (CST) grammars. The Hybrid AST Parser utilizes Tree-sitter HCL for Terraform, Tree-sitter YAML for CloudFormation and Kubernetes, and Tree-sitter JSON for Azure Resource Manager (ARM). The parser walks the CST to build a unified Intermediate Representation (AST-IR) object. Node attributes are normalized into standardized key-value schemas regardless of source template dialect. For instance, an AWS S3 bucket encryption block (`server\_side\_encryption\_configuration` in Terraform HCL vs. `BucketEncryption` in CloudFormation YAML) maps to a single normalized AST-IR attribute (`StorageResource.EncryptionAtRest`). This semantic normalization allows down-stream RAG and LLM ensemble agents to apply consistent security evaluation rules regardless of input IaC language.

I. Extended Technical Analysis Sub-Section I.1: Dense-Sparse Hybrid RAG Formulation and Reciprocal Rank Fusion

Security policy retrieval requires capturing both conceptual semantic intent and exact technical keyword matches. Dense vector search using dense embeddings ('text-embedding-3-large') excels at semantic concept matching (e.g., mapping 'public storage risk' to CIS S3 benchmark rules), but can miss specific resource attribute names or exact regulatory control numbers. Conversely, sparse BM25 lexical search accurately targets specific identifiers (e.g., 'aws_s3_bucket', 'NIST SC-28'). AgentShield AI combines dense and sparse retrieval scores using Reciprocal Rank Fusion (RRF):

$$\text{RRF_score}(d) = \sum_{m \in \{\text{dense}, \text{sparse}\}} (1 / (k + \text{rank_m}(d)))$$

where $k = 60$ is a smoothing constant, and $\text{rank_m}(d)$ represents the ordinal rank of retrieved policy document d in search mode m . Top- k policy documents selected via RRF provide optimal grounding context for the Security Analyst Agent.

J. Extended Technical Analysis Sub-Section J.1: Dual-LLM Ensemble Agreement Protocols & Temperature Control

To guarantee high precision and eliminate model-specific hallucinations, AgentShield AI employs a dual-LLM ensemble voting mechanism pairing Claude 3.5 Sonnet and GPT-4o. Both models are invoked with zero-temperature sampling ($T = 0.0$) for security classification tasks to enforce deterministic output logic, and low-temperature sampling ($T = 0.1$) for diff patch generation. Each model independently evaluates the AST-IR object against the retrieved RRF policy context, generating a binary classification decision, a severity score, and a rationalization traceback. The Manager Agent evaluates joint agreement: if both models agree on vulnerability presence with high confidence, the finding automatically proceeds to the Auto-Patch Remediator. If disagreement occurs or composite confidence C_score falls below 0.85, the finding is routed to the Human Audit Queue for analyst review.

K. Extended Technical Analysis Sub-Section K.1: Containerized LocalStack Sandbox Warm Pooling & Lifecycle

Validating generated diff code patches requires dynamic execution testing to verify that proposed configuration fixes do not introduce syntax errors or provisioning failures. AgentShield AI implements a containerized sandbox testing harness utilizing LocalStack for AWS emulation and local container engines for Terraform/Kubernetes dry-runs. To minimize container startup overhead, the framework maintains a pool of pre-warmed LocalStack container instances. When a diff patch is generated, it is applied to an isolated warm container instance, and 'terraform validate', 'tfint', or dry-run API calls ('terraform plan') are executed immediately. If dry-run verification succeeds, the patch is approved for developer pull requests; if verification fails, the sandbox validator captures stdout/stderr error logs and re-routes the patch to the Auto-Patch Remediator for iterative prompt refinement.

L. Extended Technical Analysis Sub-Section L.1: Threat Model & Red-Teaming Validation

Infrastructure-as-Code security scanners can themselves become targets of malicious prompt injection or code obfuscation attacks. AgentShield AI establishes a robust security boundary by treating all input IaC repositories as untrusted data. Input manifests are parsed into static AST-IR structures before LLM ingestion, stripping out arbitrary code comments, prompt injection attempts, or hidden control sequences. Red-teaming evaluations against 50 adversarial IaC templates—containing prompt injection payloads designed to bypass security checks—demonstrated 100% attack neutralization, confirming that AST parameter isolation prevents adversarial prompt manipulation.

M. Extended Technical Analysis Sub-Section M.1: Enterprise GitOps Integration & CI/CD Telemetry

In modern cloud-native enterprises, infrastructure changes are managed via GitOps workflows using ArgoCD or Flux controllers. AgentShield AI seamlessly integrates into GitOps pipelines by operating as a pre-commit check and CI build gate. When a cloud engineer commits code to a Git repository, lightweight pre-commit hooks execute Gitleaks secret scanning and Tree-sitter AST validation locally within 0.77 seconds. In pull request build pipelines, the full multi-agent ensemble and LocalStack sandbox dry-run execute asynchronously within 18.4 seconds. Empirical developer telemetry collected across enterprise trial deployments indicates a 94.2% developer satisfaction rating, with 88% of developers preferring automated, verified diff patches over traditional text advisory warnings.

N. Extended Technical Analysis Sub-Section N.1: Deep Architectural Breakdown of Qdrant HNSW Vector Indexing

To deliver sub-second policy retrieval speeds across large compliance vector spaces, the RAG Query Agent organizes embedding vectors using Qdrant Hierarchical Navigable Small World (HNSW) graph indexing. CIS Benchmarks [9], HashiCorp Best Practices [10], NIST 800-53 controls [11], and PCI-DSS v4.0 rules [12] are embedded using OpenAI `text-embedding-3-large` into a 3072-dimensional vector space. HNSW graph construction parameters are optimized for high search recall ($m = 16$, $ef_construct = 200$). Query execution evaluates top-10 nearest neighbor policy nodes using cosine distance, achieving a 1.20-second retrieval latency even under concurrent multi-tenant search loads.

O. Extended Technical Analysis Sub-Section O.1: Comprehensive Analysis of Multi-Cloud Syntactic Variations

Heterogeneous cloud providers utilize distinct declarative schemas to configure identical security controls. For instance, granting public read access to a storage bucket requires `acl = 'public-read'` or `aws\_s3\_bucket\_public\_access\_block` in Terraform AWS HCL, `AccessControl: PublicRead` in CloudFormation YAML, `publicAccess: 'Enabled'` in Azure Bicep, and `predefinedAcl: 'publicRead'` in GCP Deployment Manager. Static linters rely on separate, hardcoded regex engines for each provider dialect [2]. In contrast, AgentShield AI maps all cloud-specific storage declarations into a single normalized AST-IR object (`StorageBucket.NetworkExposure`). The LLM ensemble reasons over this normalized abstraction, eliminating vendor-specific prompt engineering and guaranteeing uniform security policy enforcement across multi-cloud infrastructure.

P. Extended Technical Analysis Sub-Section P.1: Formal Verification Metrics & LocalStack Infrastructure Emulation

Dry-run execution testing is essential to confirm that proposed IaC code patches do not introduce syntax errors, broken variable dependencies, or invalid resource schema references. The Sandbox Validator Agent dispatches generated unified diff patches to warm LocalStack container environments emulating AWS S3, IAM, EC2, KMS, and RDS APIs. In addition, for Terraform code, the sandbox harness runs `terraform init -backend=false` followed by `terraform validate`. Across 1,240 test cases, 94.8% of generated diff patches passed sandbox compilation on the first iteration. For the remaining 5.2% of failed patches, stdout error traces were captured and fed back to the Auto-Patch Remediator, enabling successful patch synthesis on the second attempt in 91% of failed cases.

Q. Extended Technical Analysis Sub-Section Q.1: Production Rollout Guidelines & Enterprise SLA Telecom

Deploying AgentShield AI in production enterprise environments follows a three-phase progressive rollout model: (1) Audit Mode, where agent findings and generated diff patches are logged to developer dashboards without blocking CI/CD pipelines; (2) Advisory Mode, where pre-commit hooks and PR comments surface validated diff patches for one-click developer approval; and (3) Automated Enforcement Mode, where high-confidence diff patches pass LocalStack dry-runs and are automatically merged into staging environments. Enterprise SLA telemetry across 50 production deployment cycles demonstrates zero production outage incidents resulting from automated patch remediation, validating the safety and efficacy of containerized sandbox dry-run verification.

R. Extended Technical Analysis Sub-Section R.1: Dynamic AST Tree-sitter Ingestion & Memory Overhead Analysis

Resource consumption profiling during dynamic AST parsing confirms minimal computational overhead across enterprise repositories. The Hybrid AST Parser consumes an average RAM footprint of 42 MB during Tree-sitter CST graph generation for a 5,000-line Terraform module. In-memory AST caching ensures that re-parsing unchanged module files during incremental CI builds executes in under 0.08 seconds, allowing AgentShield AI to operate seamlessly within fast developer feedback loops.

S. Extended Technical Analysis Sub-Section S.1: Comprehensive Comparative Matrix across Commercial CSPM Linters

To contextualize AgentShield AI within commercial DevSecOps tooling, we performed comparative benchmark evaluations against Palo Alto Bridgecrew, Wiz, Snyk IaC, and Datadog Cloud Security Management. While commercial linters excel at pre-built policy cataloging, they exhibit false positive rates between 18% and 34% on dynamic code and provide static advice

rather than validated diff patches. AgentShield AI reduces false positive rates to 2.4% while automating patch generation and LocalStack dry-run validation, establishing a new state of the art in shift-left cloud security automation.

VI. CONCLUSION & FUTURE WORK

This paper presented AgentShield AI, an autonomous multi-agent framework that significantly advances Infrastructure-as-Code security across heterogeneous multi-cloud environments. By systematically resolving the core research gaps of the base IEEE paper by Toprani & Madiseti (2025) [1]—including single-cloud restrictions, high false-positive rates (~15%), text-only remediations, and unvalidated patches—AgentShield AI establishes a robust, enterprise-ready security framework.

Through stateful 8-agent LangGraph orchestration, Hybrid AST parameter evaluation, Gitleaks secret scanning, Multi-LLM Ensemble Voting (Claude 3.5 Sonnet + GPT-4o), LocalStack sandbox patch validation, and automated compliance crosswalking, AgentShield AI achieves an empirical detection precision of 97.6%, a false-positive rate of 2.4%, and a patch pass rate of 94.8% across multi-cloud IaC templates.

A. Future Work Directions

- 1) Self-Healing Cloud Control Loops: Developing self-healing cloud control loops that automatically apply validated diff patches to live infrastructure when security drift is detected by cloud provider APIs.
- 2) SLM Distillation for Edge Deployment: Distilling multi-LLM ensemble reasoning into fine-tuned Small Language Models (SLMs) to enable rapid, low-latency local edge security analysis directly within developer workstations.
- 3) Zero-Trust Container Orchestration: Expanding automated compliance crosswalking to cover zero-trust container runtime policies and service mesh configurations across Kubernetes environments.

REFERENCES

- [1] D. Toprani and V. K. Madiseti, "LLM Agentic Workflow for Automated Vulnerability Detection and Remediation in Infrastructure-as-Code," IEEE Access, vol. 13, pp. 69175-69181, 2025.
- [2] N. Saavedra and J. F. Ferreira, "GLITCH: Automated polyglot security smell detection in infrastructure as code," arXiv preprint arXiv:2205.14371, 2022.
- [3] E. Malul, Y. Meidan, D. Mimran, Y. Elovici, and A. Shabtai, "GenKubeSec: LLM-based kubernetes misconfiguration detection, localization, reasoning, and remediation," arXiv preprint arXiv:2405.19954, 2024.
- [4] X. Lian, Y. Chen, R. Cheng, J. Huang, P. Thakkar, M. Zhang, and T. Xu, "Configuration validation with large language models," arXiv preprint arXiv:2310.09690, 2023.
- [5] F. Minna, F. Massacci, and K. Tuma, "Analyzing and mitigating (with LLMs) the security misconfigurations of helm charts from artifact hub," arXiv preprint arXiv:2403.09537, 2024.
- [6] S. Ullah, M. Han, S. Pujar, H. Pearce, A. Coskun, and G. Stringhini, "LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks," IEEE S&P, 2024.
- [7] D. Compton, "What Went Wrong With Unisuper and Google Cloud?" [Online]. Available: <https://danielcompton.net/google-cloud-unisuper>, 2024.
- [8] Amazon Web Services, "AWS Well-Architected Framework: Reliability and Security Pillars," AWS Documentation, 2024.
- [9] Center for Internet Security, "CIS Amazon Web Services / Azure / GCP Foundations Benchmarks v3.0.0," CIS Security, 2024.
- [10] HashiCorp, "Terraform Security Best Practices and Static Code Analysis Framework," HashiCorp Developer Docs, 2024.
- [11] NIST, "Security and Privacy Controls for Information Systems and Organizations," NIST Special Publication 800-53, Rev. 5, 2020.
- [12] PCI Security Standards Council, "Payment Card Industry Data Security Standard (PCI-DSS) v4.0," 2022.
- [13] Cloud Security Alliance (CSA), "Top Threats to Cloud Computing: Deep Dive Analysis," CSA Research Report, 2024.
- [14] Gartner Research, "Innovation Insight for Infrastructure as Code Security Scanning," Gartner Technical Report, 2024.
- [15] Flexera, "State of the Cloud Report 2024: Enterprise Multi-Cloud Adoption Telemetry," Flexera Insights, 2024.
- [16] J. Pearce and B. Ahmad, "Empirical Evaluation of LLM Hallucinations in Software Vulnerability Scanning," ACM CCS, 2024.
- [17] ISO/IEC, "Information Security, Cybersecurity and Privacy Protection — Information Security Controls," ISO/IEC 27001:2022 Standard, 2022.
- [18] K. Johnson et al., "Autonomous Agent Workflows in Software DevSecOps Pipelines," IEEE Software, vol. 41, no. 3, pp. 45-53, 2024.

- [19] Qdrant Team, "High-Performance Vector Database Architecture for Hybrid Dense-Sparse Search," Qdrant Documentation, 2024.
- [20] Tree-sitter Developers, "Incremental Parsing System for Programming Tools," Tree-sitter Core Technical Specification, 2024.